CyberUW

Supplementary: Security Controls

Supplementary questionnaire

Form reference CYBERUW-IQ-1.0-SEC · Aligned to underwriting model UNDERWRITING_MODEL_V1

Applicant reference

Applicant legal name		**Submission reference**	
Completed by (name / role)		**Date completed**	
Broker / intermediary		**Requested effective date**	

How to complete this form

Answer every question in every applicable section. Where a question does not apply, write **N/A** and state briefly why, rather than leaving the field blank - an unanswered question is not treated as a favourable answer.

Several questions ask whether a control is *enforced* rather than whether it is *available*. These are different, and the distinction changes the price. Where a question asks for a date, a percentage or a measured rate, give the actual figure rather than a general assurance. Attaching supporting evidence (audit reports, configuration exports, restore-test records) improves the rating for a given security posture and is strongly encouraged.

Section E - Network Architecture & Segmentation

Assessed controls: *Network segmentation (Tier 2), vulnerability management (Tier 2), asset inventory (Tier 3), logging & monitoring (Tier 3)*

Ref	Question	Response
E1	Are critical systems and applications hosted centrally, or distributed?	
E2	Is the network segmented (VLANs, firewalls between zones), or is it largely flat?	
E3	How are applications isolated from one another to limit the spread of an incident?	
E4	Is a Web Application Firewall in place protecting externally facing applications?	
E5	Frequency and scope of penetration testing (external-facing systems; internal systems). State the date of the most recent test.	
E6	Are the results of the most recent penetration test available to share?	
E7	Is remote access secured via VPN, Zero Trust Network Access or similar? Is Remote Desktop Protocol used, and if so, how is it secured or restricted?	
E8	What network monitoring tools are available, and are they actively used?	
E9	Is a current inventory of hardware, software and data assets maintained? State how it is produced (discovery tooling, CMDB, manual) and when it was last reconciled.	

Evidence attached for this section (list artefact and date):

Section F - Identity & Access Management

Assessed controls: *Multi-factor authentication (Tier 1), privileged access management (Tier 2), password policy (Tier 3), logging & monitoring (Tier 3)*

Ref	Question	Response
F1	Is Multi-Factor Authentication enforced - not merely available - on each of the following?	
F1.1	Email / webmail	
F1.2	VPN and remote access	
F1.3	Privileged and administrative accounts	
F1.4	Business-critical cloud applications	
F2	What MFA method is used (authenticator application, hardware token, push approval, or SMS)?	
F3	Are any accounts exempt from MFA (service accounts, emergency or break-glass accounts)? How are those secured instead?	
F4	Is there a formal Identity and Access Management programme?	
F5	How many users hold privileged or administrative access to the network or directory service?	
F6	Are privileged accounts separate from standard user accounts, with separate credentials?	
F7	Is privileged account activity monitored and logged, and are sessions automatically terminated when idle?	
F8	Is a password policy technically enforced? State the enforced minimum length, complexity or passphrase standard, lockout threshold and reuse restriction, and where each is enforced.	
F9	Are access and authentication logs retained? For how long, and where are they stored?	

Evidence attached for this section (list artefact and date):

Section G - Email Security

Assessed controls: *Email security (Tier 2), security awareness training (Tier 3), outside-in cross-check*

Ref	Question	Response
G1	Is a secure email gateway in place that scans and filters incoming mail for malware and phishing?	
G2	Are SPF, DKIM and DMARC enforced on all company email domains? State the DMARC policy in force (none / quarantine / reject).	
G3	Is email attachment sandboxing used?	
G4	Are Microsoft Office macros disabled by default?	
G5	Do employees receive regular phishing and social engineering awareness training? State the frequency, whether phishing simulation testing is performed, and the most recent recorded failure rate.	

Evidence attached for this section (list artefact and date):

Section H - Endpoint Security, Monitoring & Detection

Assessed controls: *Endpoint detection & response (Tier 1), logging & monitoring (Tier 3)*

Ref	Question	Response
H1	Is Endpoint Detection and Response, Managed Detection and Response, or Extended Detection and Response deployed?	
H1.1	Vendor and product name	
H1.2	Percentage of endpoints covered	
H1.3	Monitoring model - in-house SOC, 24x7 managed service, or business hours only	
H1.4	Can it automatically isolate or block malicious activity?	
H2	Is a SIEM in place aggregating logs? What percentage of critical systems feed into it?	
H3	Is there a Security Operations Centre (in-house, outsourced or hybrid)?	
H4	Is threat intelligence used to proactively identify risks?	

Evidence attached for this section (list artefact and date):

Section I - Vulnerability & Patch Management

Assessed controls: *Critical patching process (Tier 1), vulnerability management (Tier 2), secure configuration (Tier 3)*

Ref	Question	Response
I1	Is there a formal, documented patch management process?	
I2	Target timelines for patching, by severity	
I2.1	Critical	
I2.2	High	
I2.3	Medium	
I2.4	Low	
I3	Compliance rate against those targets over the past twelve months	
I4	Frequency and scope of internal and external vulnerability scans	
I5	Are patches tested in a non-production environment before broad deployment?	
I6	Average time to remediate vulnerabilities after discovery, and to install patches after release, over the last three years	
I7	Are hardening baselines applied to servers, endpoints and cloud workloads (CIS Benchmarks, vendor baselines or equivalent)? State which baseline, how compliance is measured, and how often it is reviewed.	

Evidence attached for this section (list artefact and date):

Section J - Backup, Business Continuity & Disaster Recovery

Assessed controls: *Tested backups (Tier 1)*

Ref	Question	Response
J1	Backup frequency and method for critical systems and data	
J2	Where are backups stored, and are they:	
J2.1	Encrypted?	
J2.2	Immutable, or Write-Once-Read-Many?	
J2.3	Offline / air-gapped, or otherwise segmented from the production network?	
J2.4	Protected by MFA and / or a separate privileged account?	
J3	Are full restore tests performed at least annually, and do they test both recoverability and data integrity? State the date and outcome of the most recent test.	
J4	What are the Recovery Time Objective and Recovery Point Objective for critical systems?	
J5	Are alternate or failover systems maintained for critical applications?	
J6	Is there a written business continuity and disaster recovery plan? When was it last reviewed, and when was it last exercised?	

Evidence attached for this section (list artefact and date):

Section K - Cloud Security

Assessed controls: *Secure configuration (Tier 3), concentration exposure, claims history*

Ref	Question	Response
K1	What cloud platforms and services does the company use (IaaS, PaaS, SaaS)? Name the principal providers.	
K2	Is there a formal cloud security policy, and how regularly is it reviewed?	
K3	What measures, controls and compliance standards are applied to secure cloud environments, and how frequently are configurations reviewed?	
K4	How business-critical are the services provided from the cloud?	
K5	Has the company ever experienced an incident originating with a cloud provider? If yes, state what happened, why, and the business impact.	

Evidence attached for this section (list artefact and date):

Section L - Third-Party & Vendor Risk Management

Assessed controls: *Contingent exposure, regulatory severity overlay*

Ref	Question	Response
L1	Is there a dedicated resource responsible for vendor risk management?	
L2	Are technology vendors assessed for security posture before contracting, and periodically thereafter (security questionnaires, SOC 2 reports, penetration test results, ratings services such as BitSight or SecurityScorecard)?	
L3	Are Data Protection Agreements in place with vendors that handle sensitive data?	
L4	Do vendor contracts specify who is responsible for breach notification and response where the incident originates with the vendor, and do they contain indemnification clauses?	
L5	Are alternative providers identified or contracted for business-critical outsourced services in the event of an outage?	
L6	How many third-party vendors and suppliers are engaged, and what services do they provide?	
L7	How business-critical or risky are the services provided by third parties?	

Evidence attached for this section (list artefact and date):

Section M - Payment Card & Funds Transfer Fraud Controls

Assessed controls: *Funds transfer fraud coverage head, security awareness training (Tier 3), claims history*

Ref	Question	Response
M1	Does the company process, store or transmit payment card data directly, or through a third-party processor?	
M2	If applicable, what is the PCI-DSS compliance level and validation method?	
M3	Does the company use a wire or funds transfer system to pay vendors and third parties?	
M4	Are formal verification procedures required before changing payment instructions or executing a funds transfer request (for example, a callback to a previously known number)?	
M5	Do employees who handle payments receive specific training on business email compromise and social engineering fraud?	
M6	Has the company experienced any funds transfer fraud or social engineering fraud loss in the past three years?	
M7	What was the volume and value of online funds transfers in each of the last three years?	

Evidence attached for this section (list artefact and date):

Section N - Incident Response & Training

Assessed controls: *Incident response plan (Tier 2), security awareness training (Tier 3)*

Ref	Question	Response
N1	Is there a formal, written Incident Response Plan?	
N2	Has it been tested by tabletop exercise or live simulation in the past twelve months? State the date and format of the most recent exercise.	
N3	Is there a named internal incident response team, or a retained external incident response / forensics firm on standby?	
N4	Do all employees receive cybersecurity awareness training? State the frequency and the completion rate.	
N5	When was the Incident Response Plan last reviewed and updated?	

Evidence attached for this section (list artefact and date):

Declaration

I confirm that the information given in this form is true and complete to the best of my knowledge and belief, having made reasonable enquiry within the organisation. I understand that this information will be relied upon in assessing the risk and determining the premium, and that the answers given in the identity-and-access, endpoint, patching and backup sections may be incorporated into the policy as continuing warranties. I undertake to notify the insurer of any material change to the information given here between the date of this declaration and the inception of cover.

Name		**Signature**	
Designation		**Date**	
Company		**Place**	

This form is a research and educational instrument produced as part of the CyberUW capstone project. It is not an insurer's proposal form, and completion of it does not constitute an offer, a proposal, or the binding of insurance cover. It is not legal, regulatory, actuarial or insurance advice.